



EMBARCADERO CONFERENCE 2025

A JORNADA DO HERÓI | 30 ANOS DE INOVAÇÃO



HORSE COM OAUTH E JWT: CONTROLANDO ACESSOS AOS RECURSOS DA SUA APLICAÇÃO

Gabriel Fabrega

"Entenda os fluxos OAuth e como implementá-los em Delphi com Horse. Abordaremos tipos de tokens (JWT e opaco), segurança, performance, validação, proteção de rotas e controle de acesso por permissões."

Avalie minha palestra lendo o QRCode pelo APP OFICIAL DO EVENTO



Quem sou eu...

GABRIEL FABREGA



Bragança Paulista

Técnico em Informática
e redes



Treinamento Oficial
Embarcadero



Gestão da
T.I

Fatec
Bragança Paulista
Jornalista Omar Fagundes
de Oliveira



Tech Lead



AGROTIS

O software do Agronegócio no Brasil



@FABREGA_DEV



Avalie minha palestra lendo o QrCode pelo APP OFICIAL DO EVENTO

Agenda

- O que é OAuth
- Tipos de Token
- JWT
- Assinatura do JWT
- Fluxos OAuth
- Permissões
- Mão no código

Antes de começar, baixe o aplicativo oficial do evento



Embarcadero
Conference 25



Avalie minha palestra lendo o QRCode pelo APP OFICIAL DO EVENTO

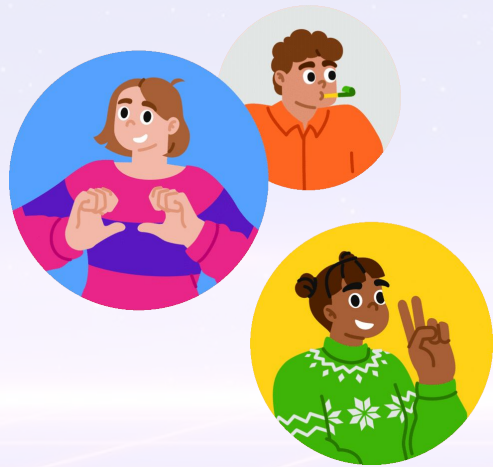
O que é OAuth

Conjunto de regras e especificações para autorização de acesso aos recursos protegidos de uma API, em nome de um usuário ou aplicação.



Para implementarmos o OAuth nas nossas aplicações, temos que entender os 4 papéis especificados.

Resource Owner



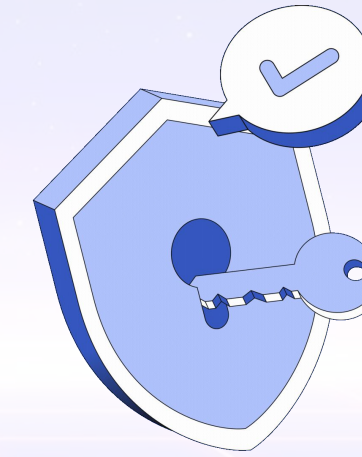
Entidade que detém os recursos protegidos. É o dono dos recursos, que pode autorizar o acesso aos recursos em seu nome

Client



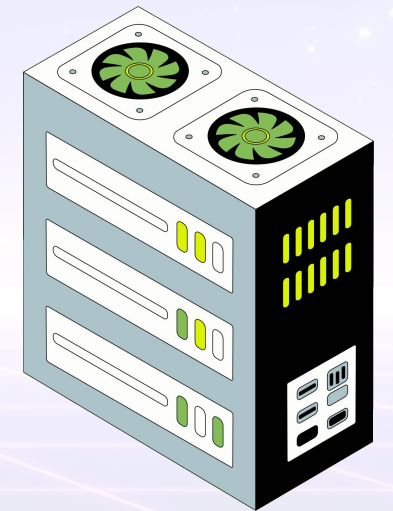
Aplicação cliente cujo interesse é acessar os recursos protegidos do Resource Server

Authorization Server



Servidor que autentica o Resource Owner e Client garante autorizações de acesso aos recursos do resource server

Resource Server



Servidor que hospeda os recursos protegidos, ou seja, nossa API



Tipos de Token

Avalie minha palestra lendo o QrCode pelo APP OFICIAL DO EVENTO



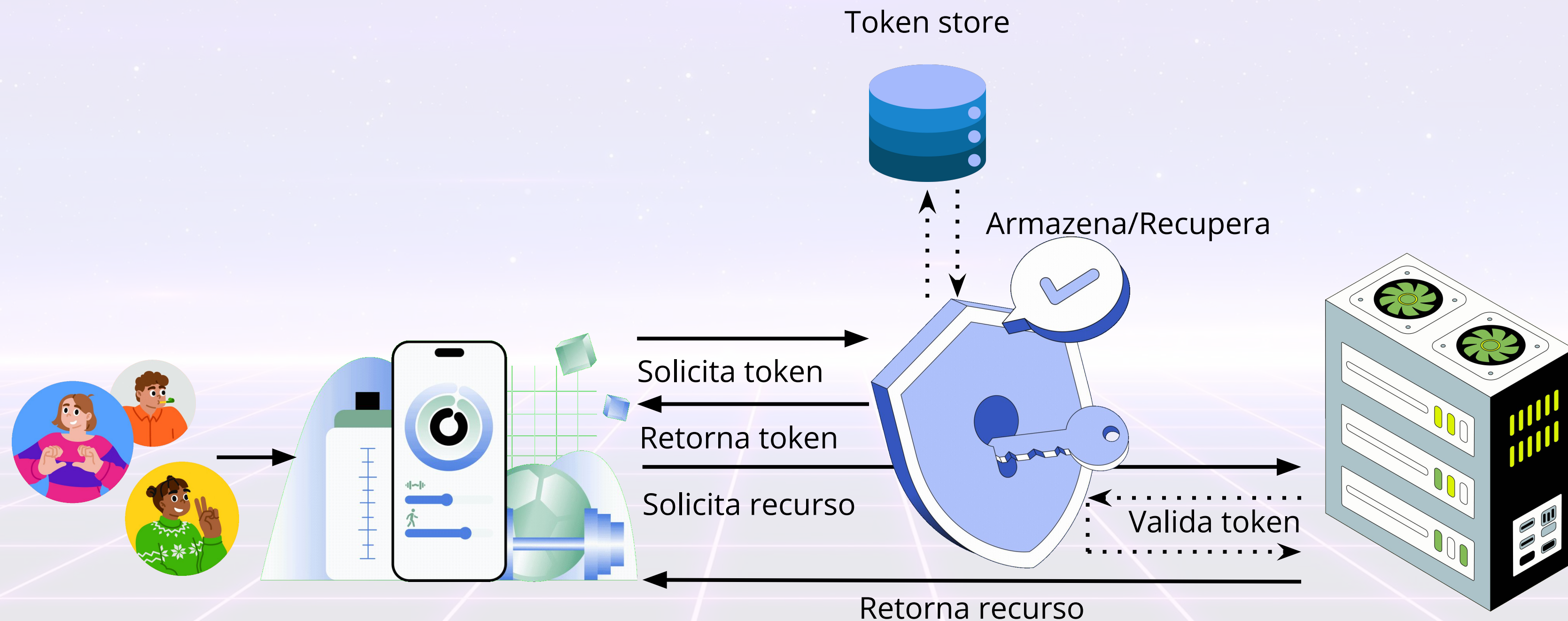
Token Opaco (Stateful)

É um token que consiste em uma string aleatória, sem qualquer informação autocontida.

- É revogável
- Dados podem ser alterados a qualquer instante
- Requer infraestrutura
- Cria dependência com o Authorization Server, que se torna um ponto de falha, e pode necessitar replicação.



Token Opaco (Stateful)



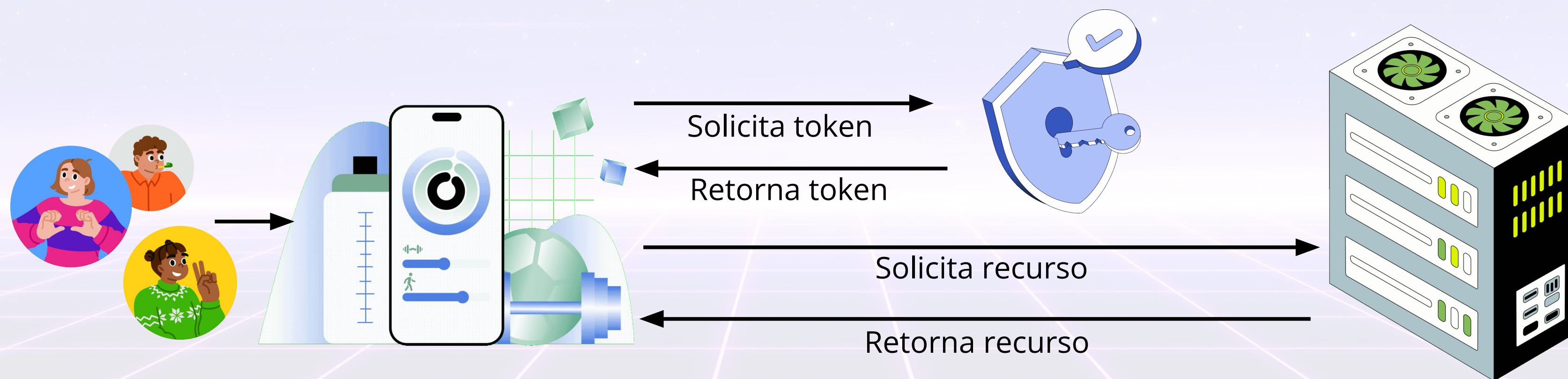
Token Transparente (Stateless)

É um token com informações em sua composição. Ele não é armazenado após sua emissão, apenas tem sua integridade verificada através de uma assinatura.

- É escalável
- Não pode conter dados sensíveis
- Após emitido, não depende de infraestrutura para ser validado
- Não é revogável
- Não pode ser alterado, por isso, pode ser inconsistente por um período
- Por conter informações, é naturalmente maior



Token Transparente (Stateless)



JWT

Avalie minha palestra lendo o QrCode pelo APP OFICIAL DO EVENTO



JWT

Formato de token transparente, composto por objetos JSON, especificado na RFC-7519 e estabelece uma troca segura de informações entre duas ou mais partes

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4gRG9lIiwiaWF0IjE5OTYxMjM0NTY3ODkw.eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4gRG9lIiwiaWF0IjE5OTYxMjM0NTY3ODkw.KMUFsIDTnFmyG3nMiGM6H9FNFUROf3wh7SmqJp-QV30
```

Header

```
{
  "alg": "RS256",
  "typ": "JWT",
  "kid": "duH80LNhuwFiw6f88Bsu9Y"
}
```

Payload

```
{
  "exp": 1756161558,
  "iat": 1756161498,
  "jti": "2cf61100-ab4f-4b4a-b8c1-d233a44c551e",
  "iss": "https://keycloak.fabregaserver.cloud/realms/master",
  "sub": "13b5aea4-b4a2-4d08-a430-c6f908695826",
  "typ": "Bearer",
  "azp": "erp-desktop",
  "sid": "f0160b23-6c1f-4886-857d-d738ff7fb814",
  "aud": "4"
}
```

Signature

**Header e Payload assinados
com uma chave simétrica ou
assimétrica**



Assinatura do JWT

Avalie minha palestra lendo o QrCode pelo APP OFICIAL DO EVENTO



Chave simétrica

Frase secreta utilizada para assinar e validar um JWT.

Deve ser conhecida por quem emite o token e quem deverá validar este token.

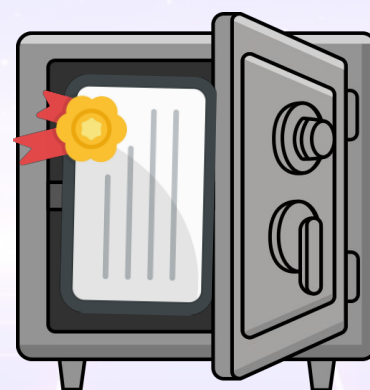
m!nh@_fr@s&_s&(r&t@_&(0n25!



Chave assimétrica

Par de certificados digitais compostos por:

Chave Privada: Assina JWTs e deve ser armazenada com extrema segurança;



Chave Pública: Apenas valida tokens assinados pelo seu par e pode ser compartilhado livremente



Fluxos OAuth

Avalie minha palestra lendo o QRCode pelo APP OFICIAL DO EVENTO

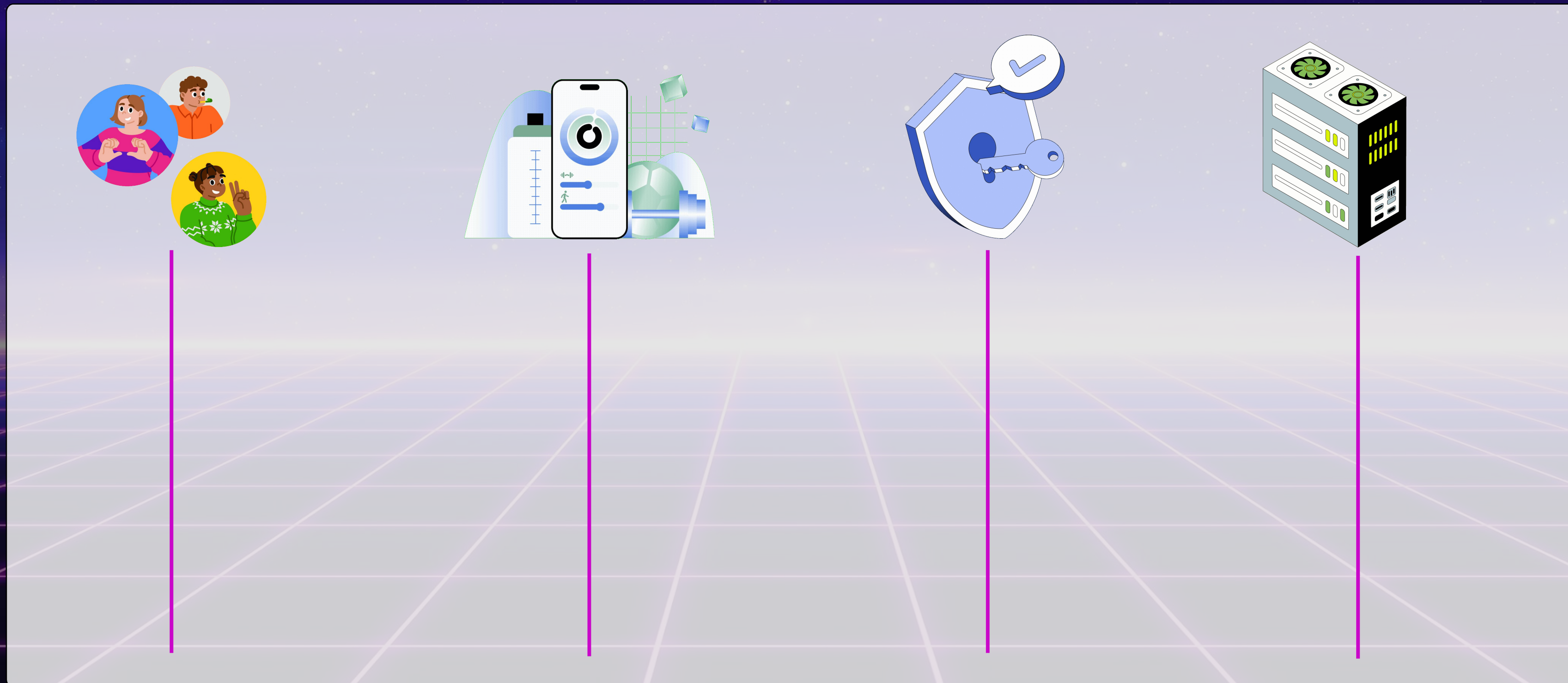


1. Password Flow

Obtém um token de acesso a partir de um usuário e senha.
Este fluxo é comumente usado quando apenas você desenvolve os clients consumidores de sua API



1. Password Flow



Avalie minha palestra lendo o QrCode pelo APP OFICIAL DO EVENTO



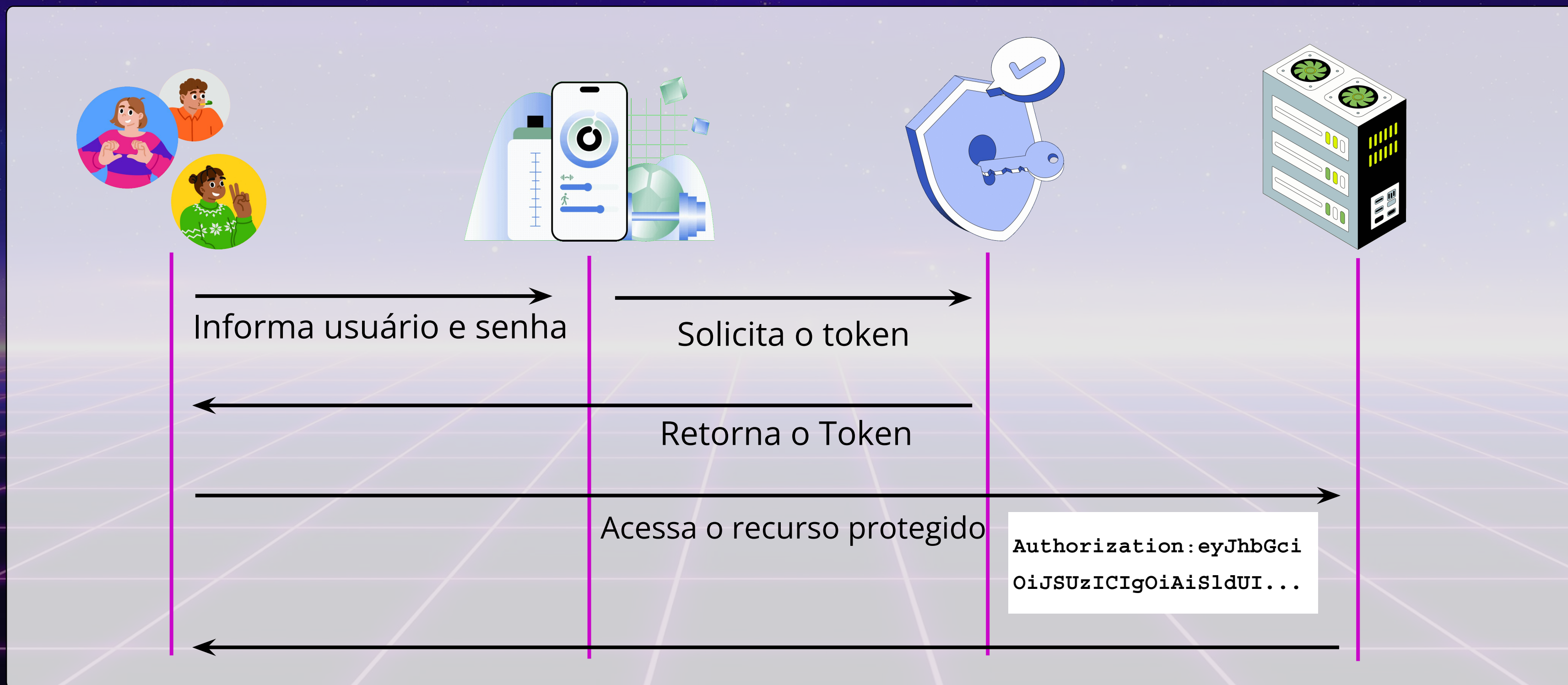
1. Password Flow



1. Password Flow



1. Password Flow

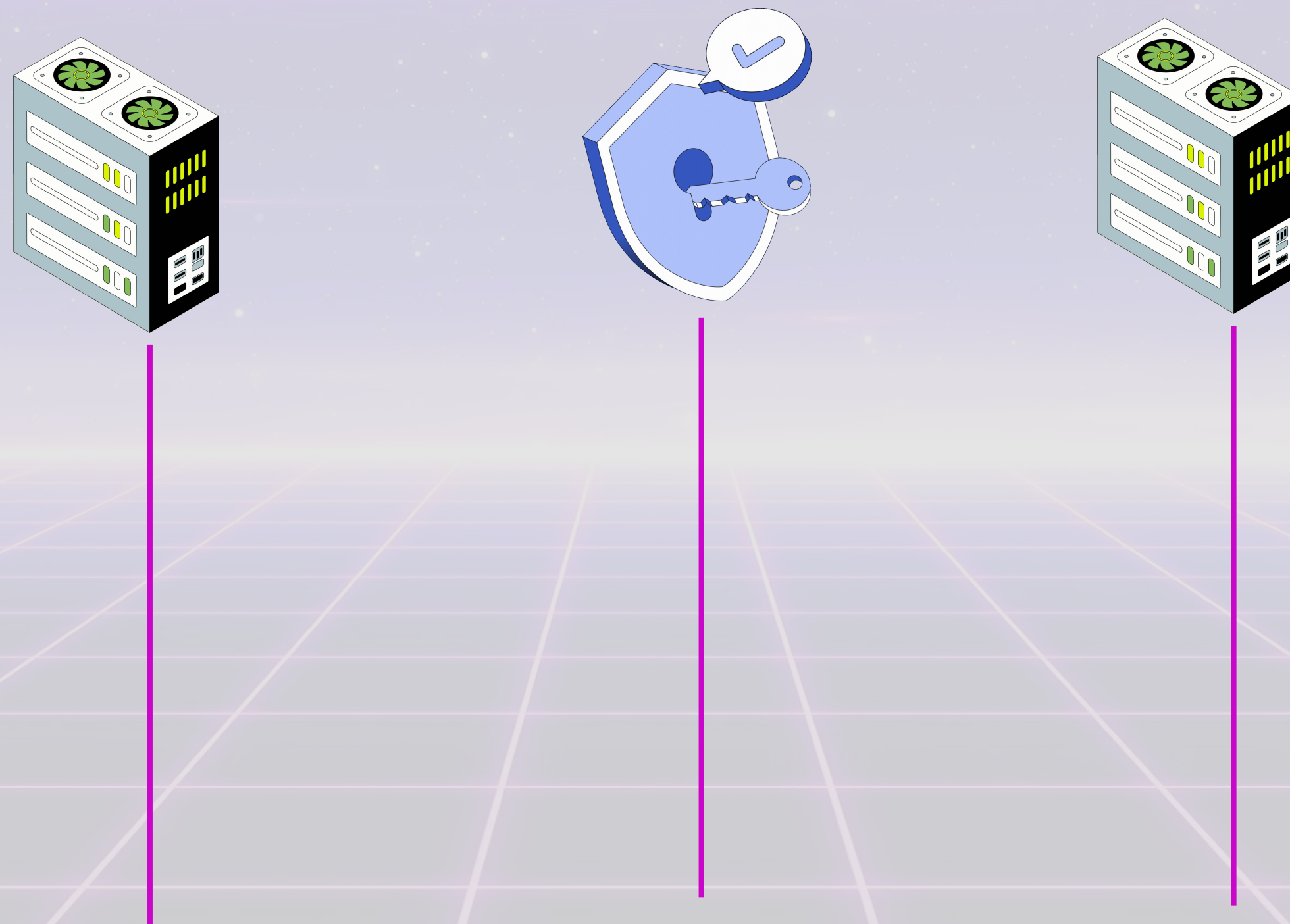


2. Client Credentials

Utilizada apenas para comunicação entre serviços backend, automações e tarefas de sistema. Não possui interação com o usuário.



2. Client Credentials



Avalie minha palestra lendo o QRCode pelo APP OFICIAL DO EVENTO



2. Client Credentials



2. Client Credentials



2. Client Credentials



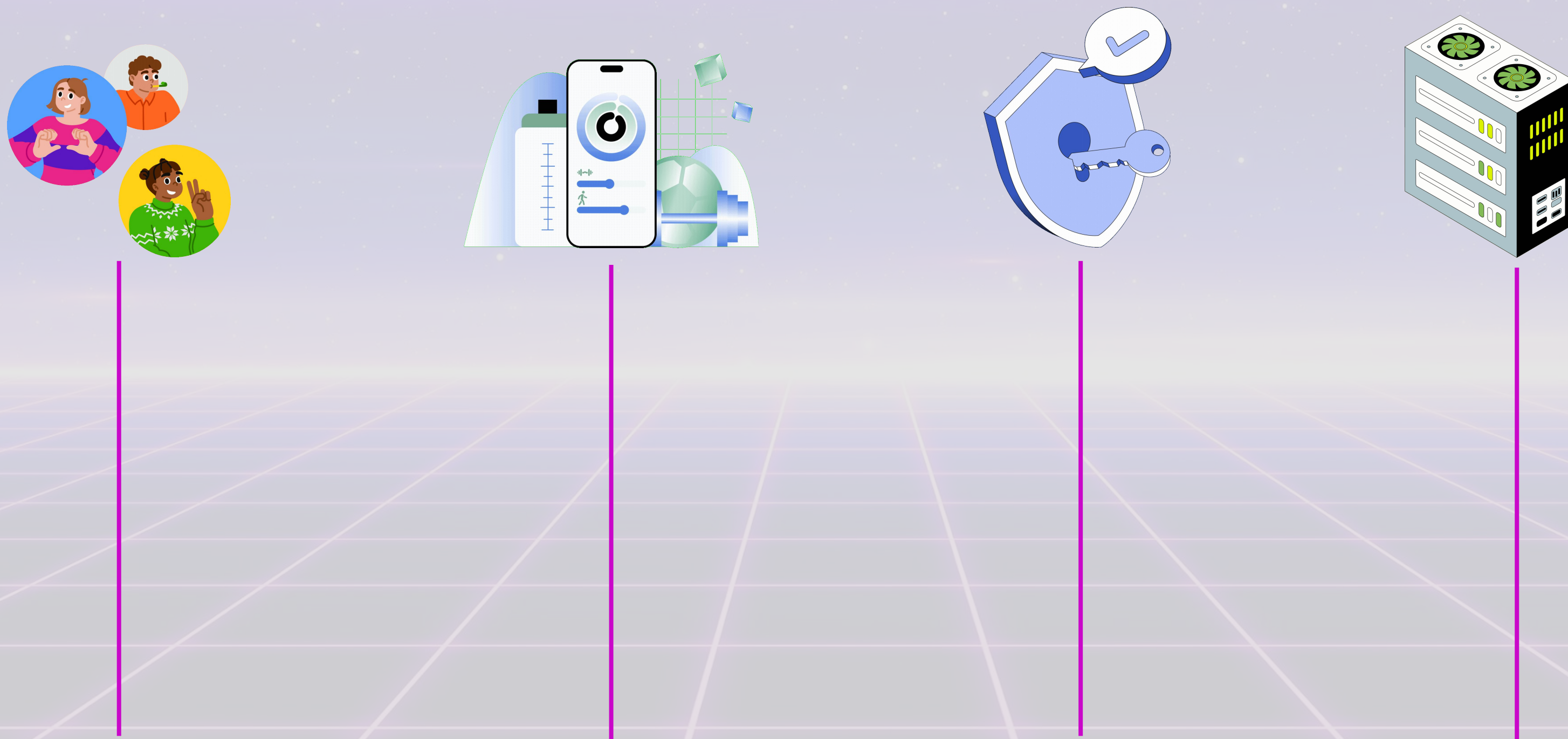
3. Authorization Code

Obtém código de autorização através da autenticação direta no Authorization Server, e, em seguida, troca-o por um token.

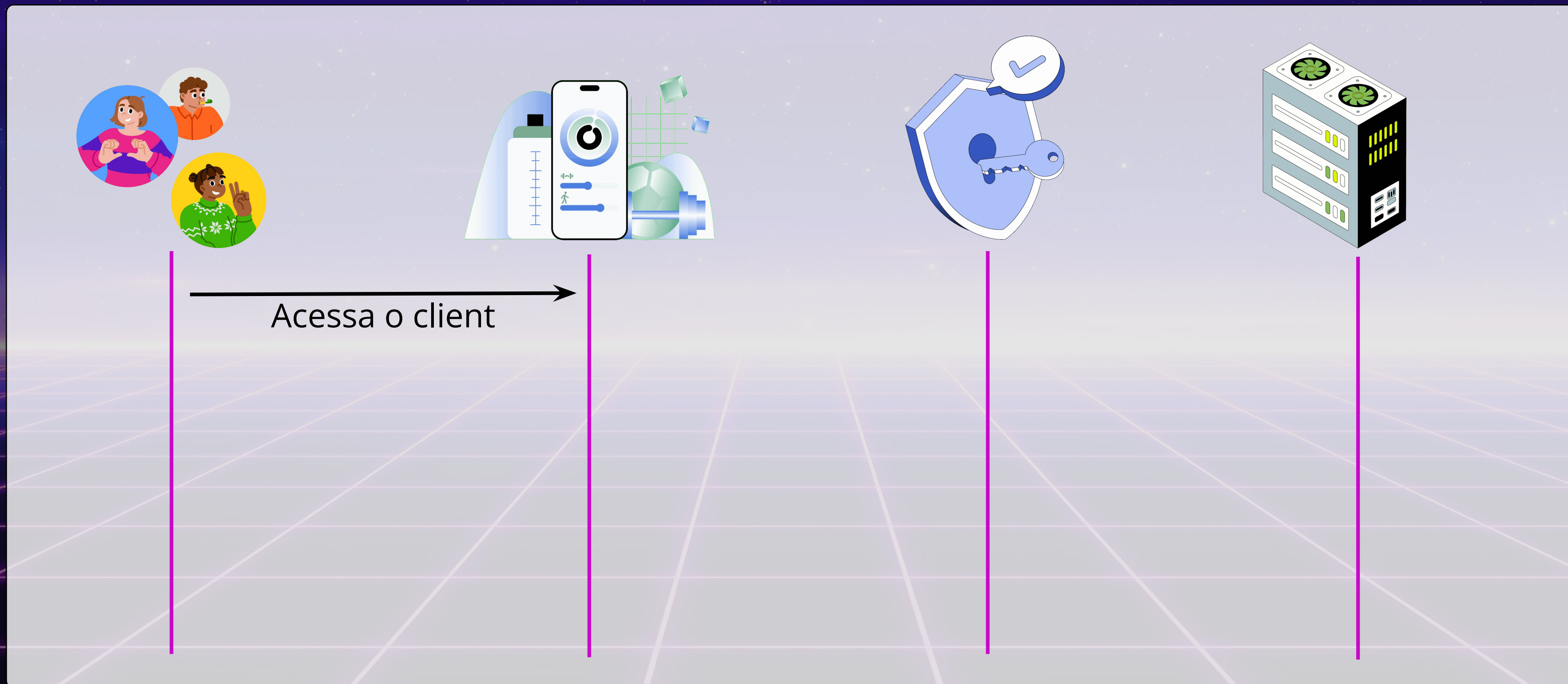
Neste caso, o client não precisa ter acesso às credenciais do usuário.



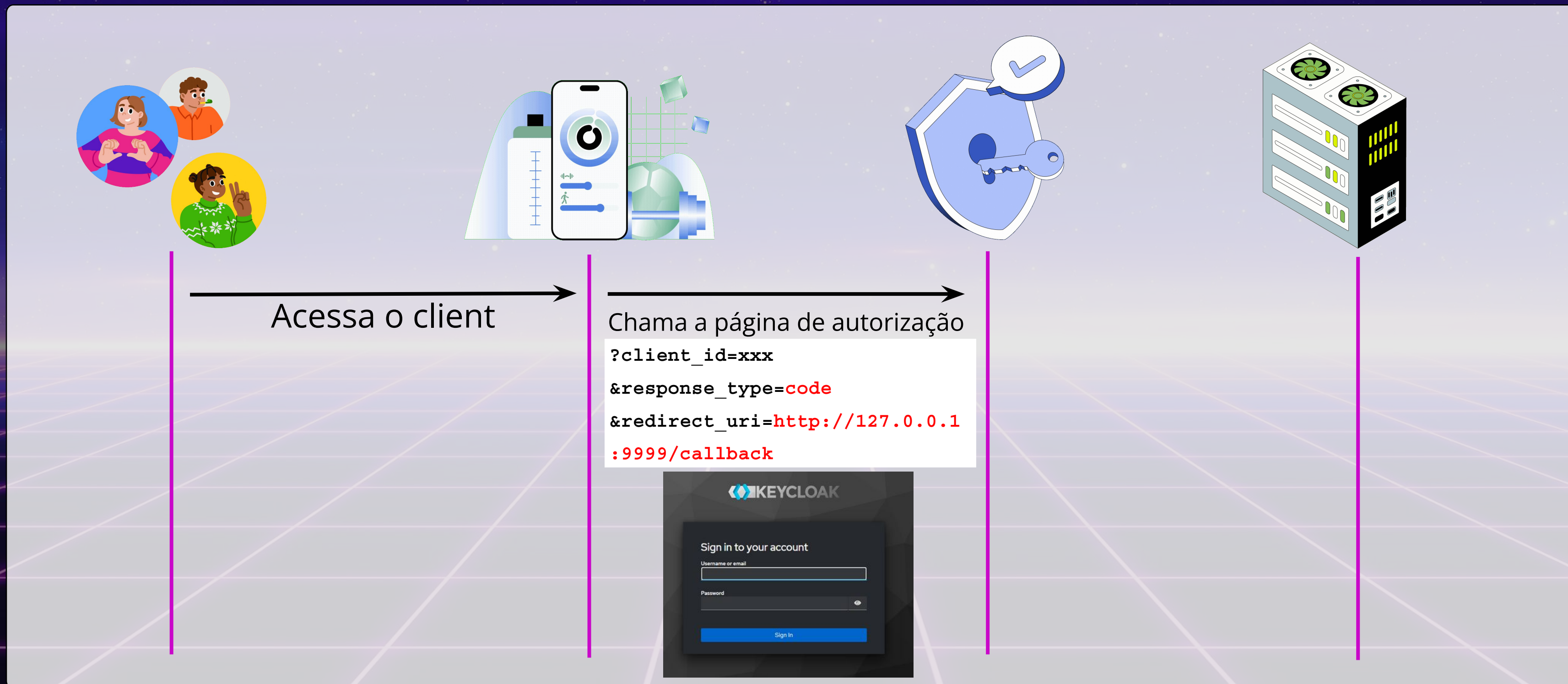
3. Authorization Code



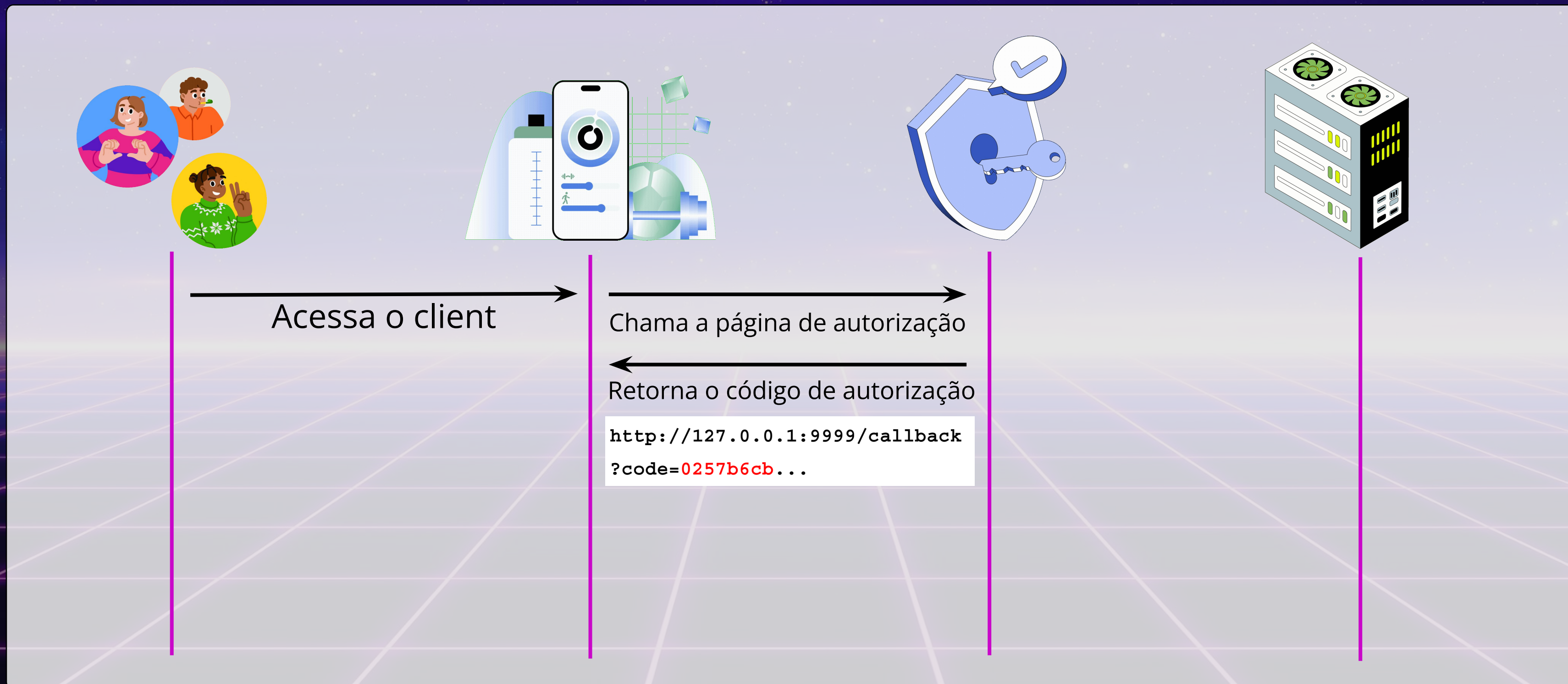
3. Authorization Code



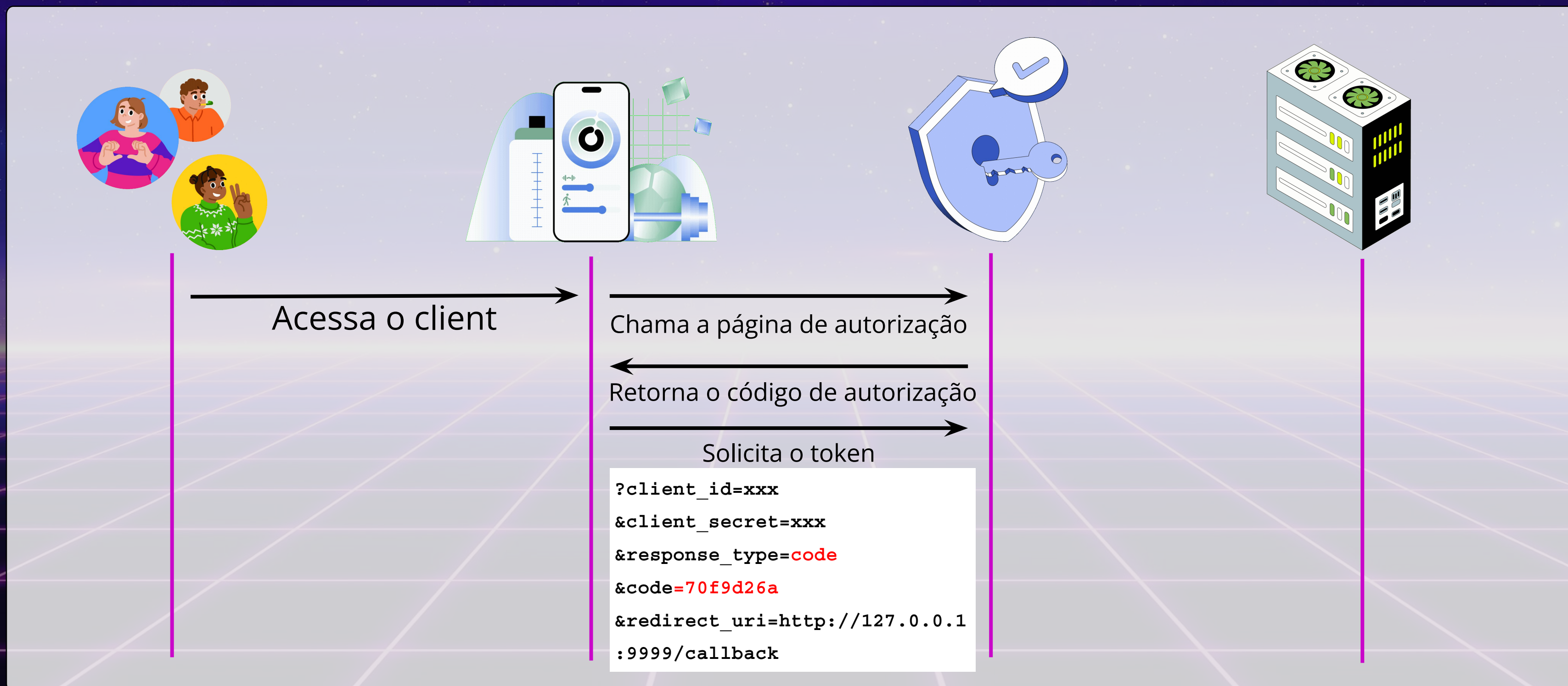
3. Authorization Code



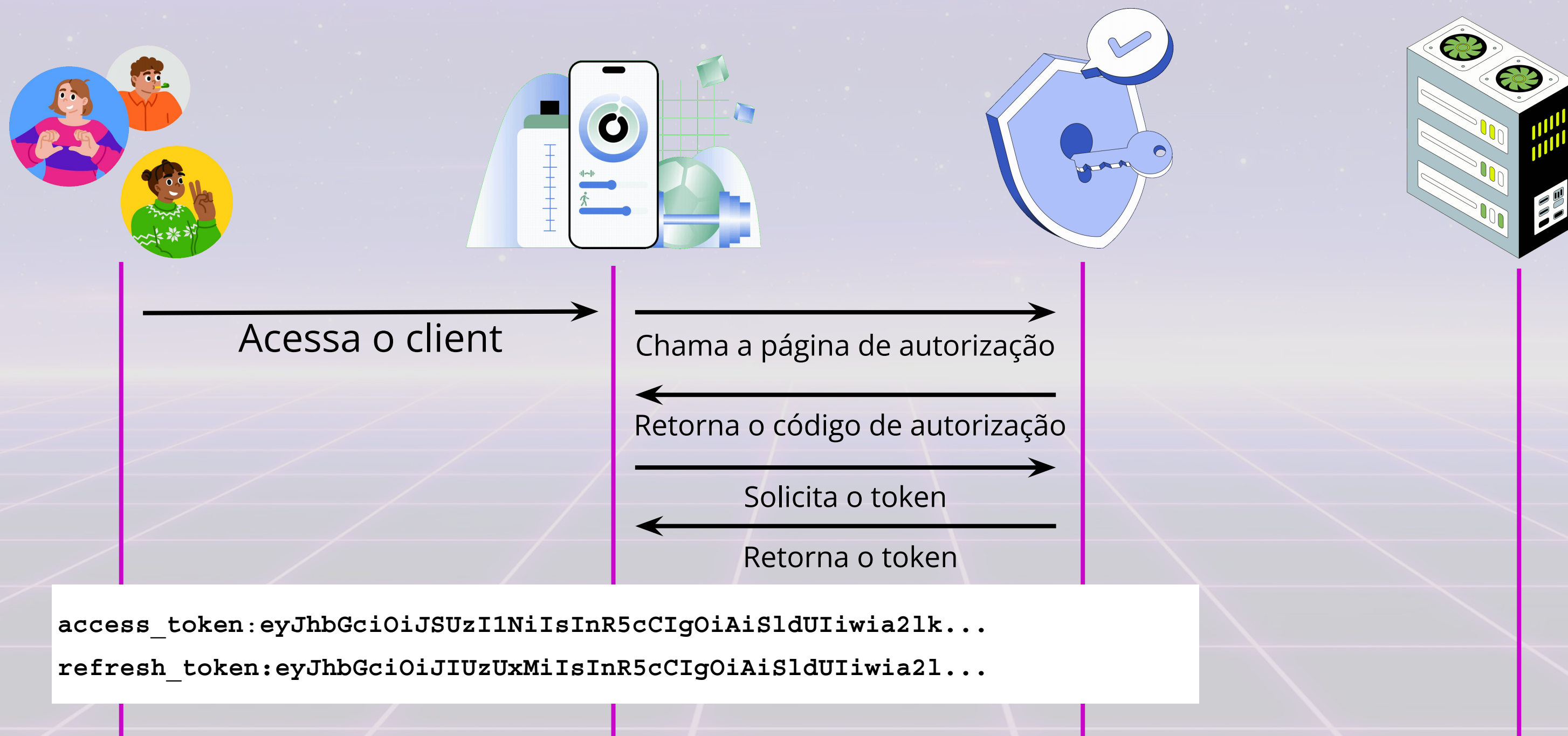
3. Authorization Code



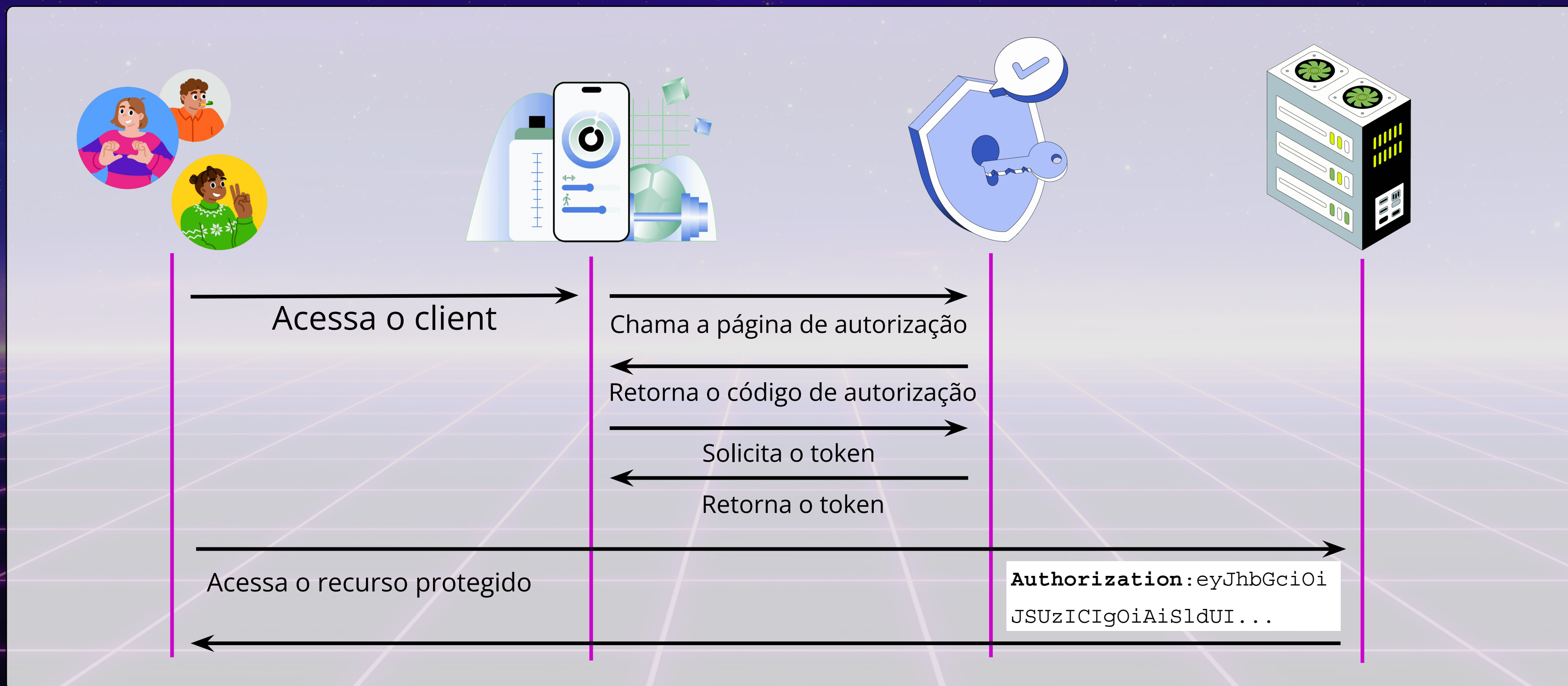
3. Authorization Code



3. Authorization Code



3. Authorization Code

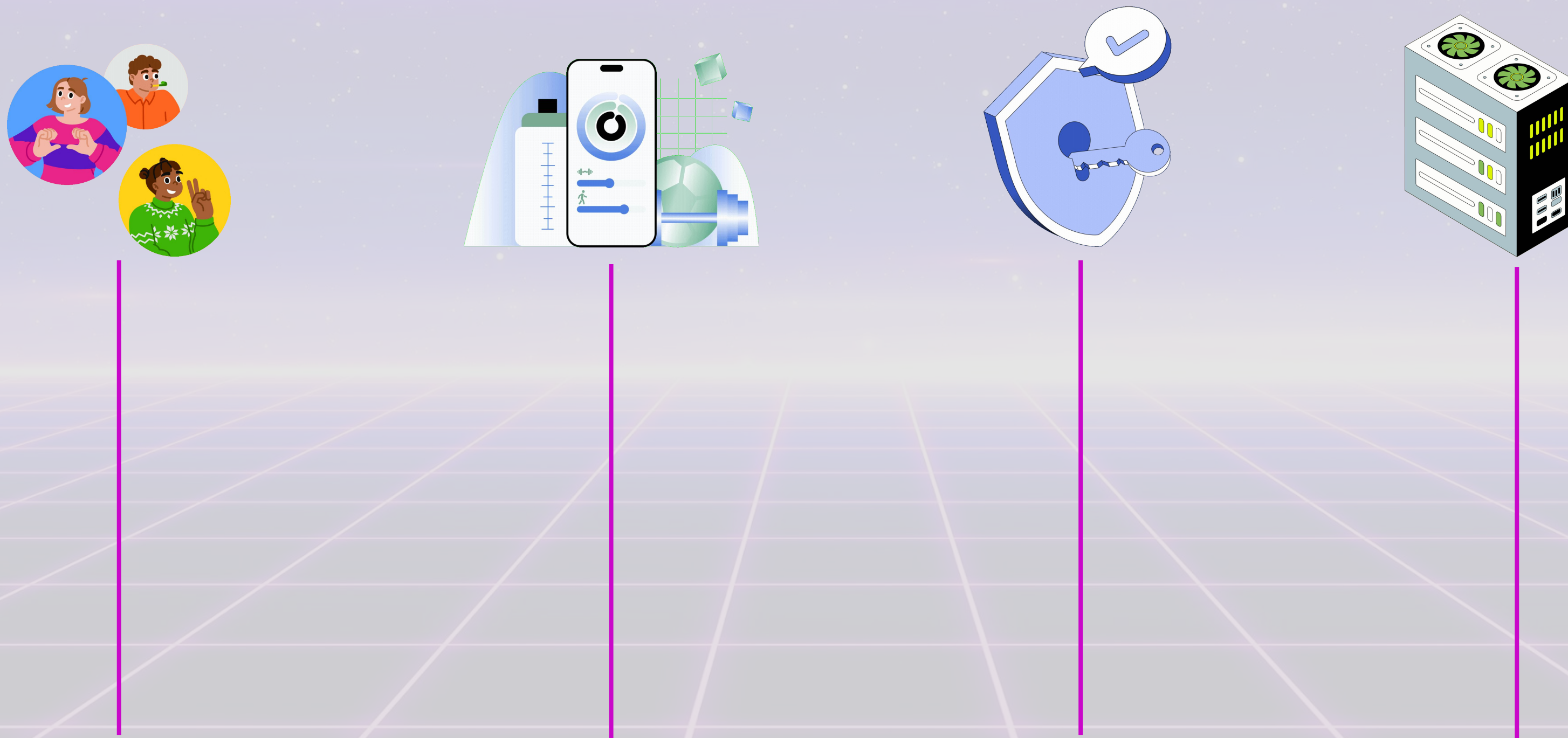


4. Authorization Code + PKCE

Adiciona uma camada extra de segurança ao fluxo Authorization Code. Este fluxo é indicado para aplicações públicas (Sites, Apps, SPAs) que não tem capacidade de armazenar as credenciais do client de forma segura



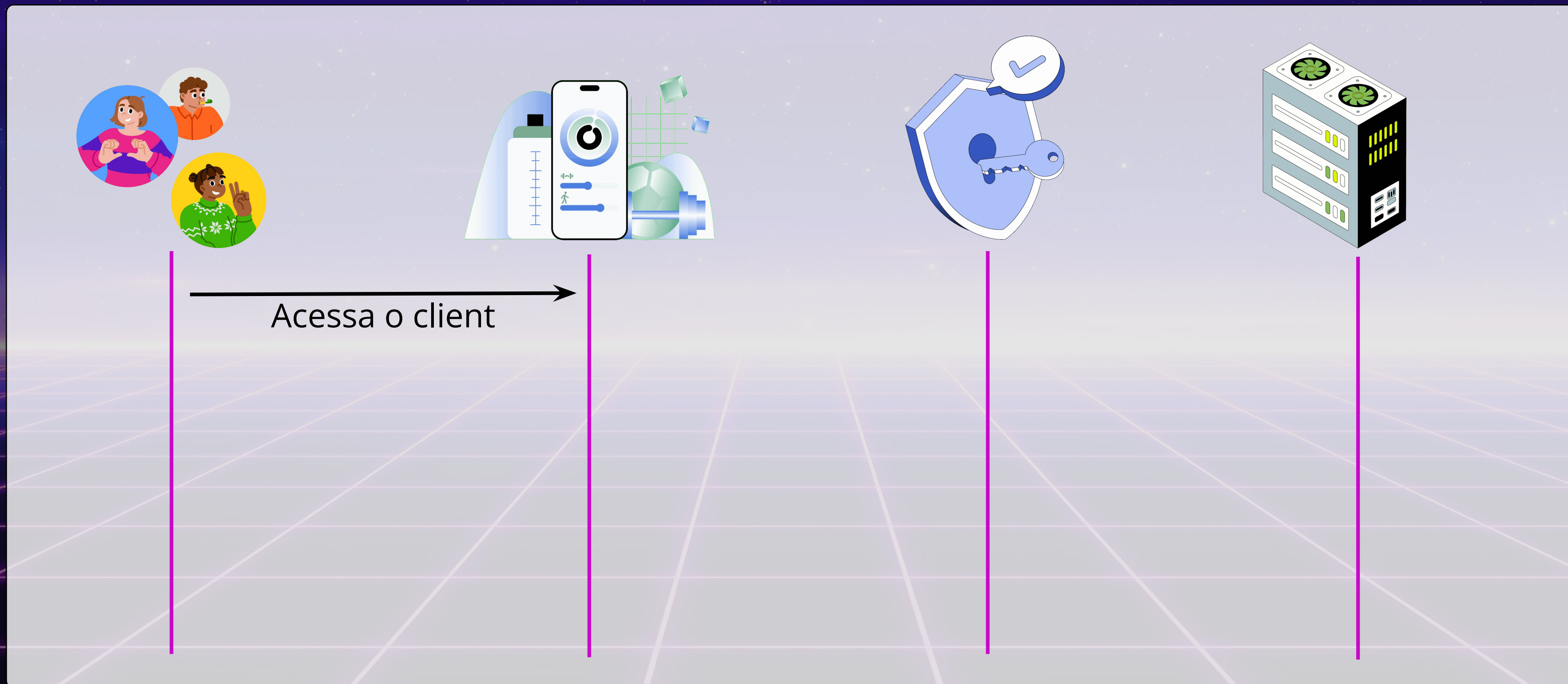
4. Authorization Code + PKCE



Avalie minha palestra lendo o QrCode pelo APP OFICIAL DO EVENTO



4. Authorization Code + PKCE



4. Authorization Code + PKCE



Acessa o client

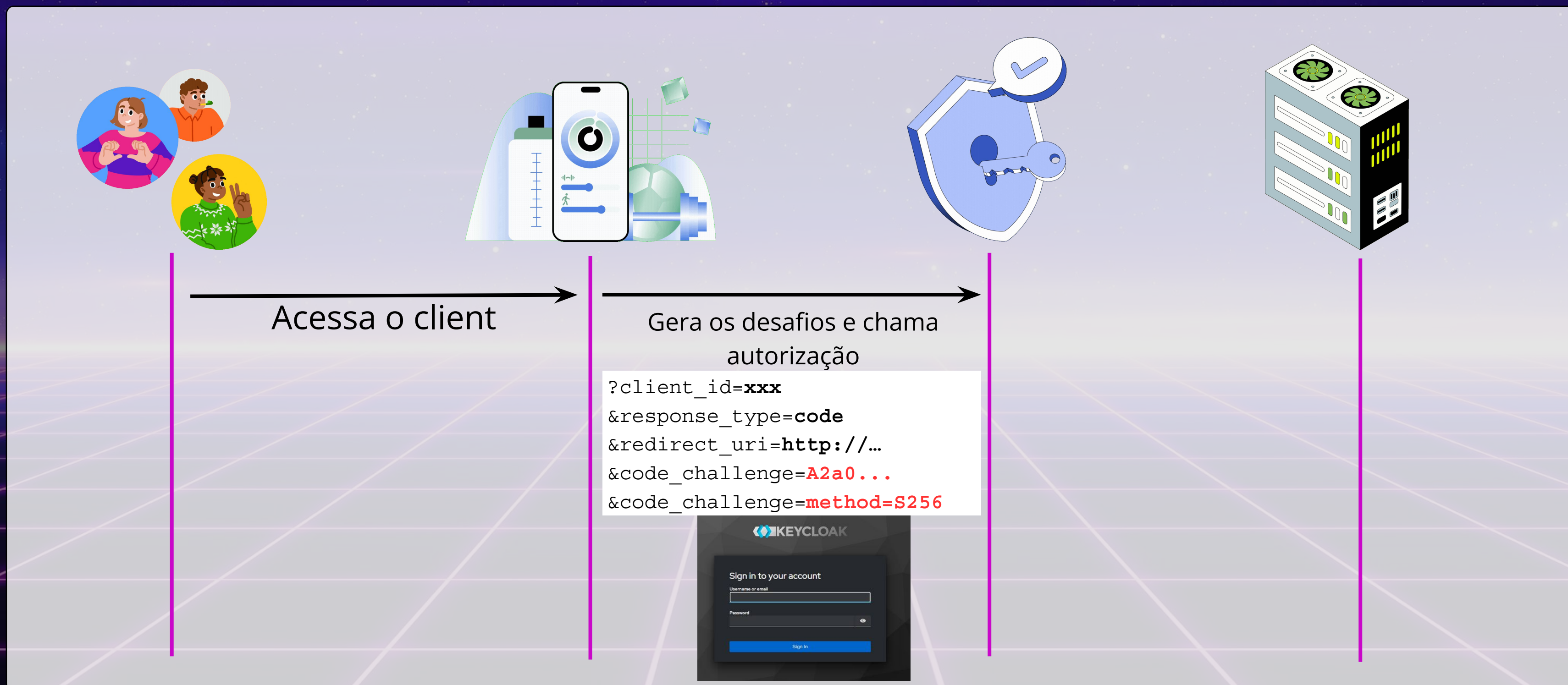
Gera os desafios e chama
autorização

Code Verifier: String aleatória de 128 chars.

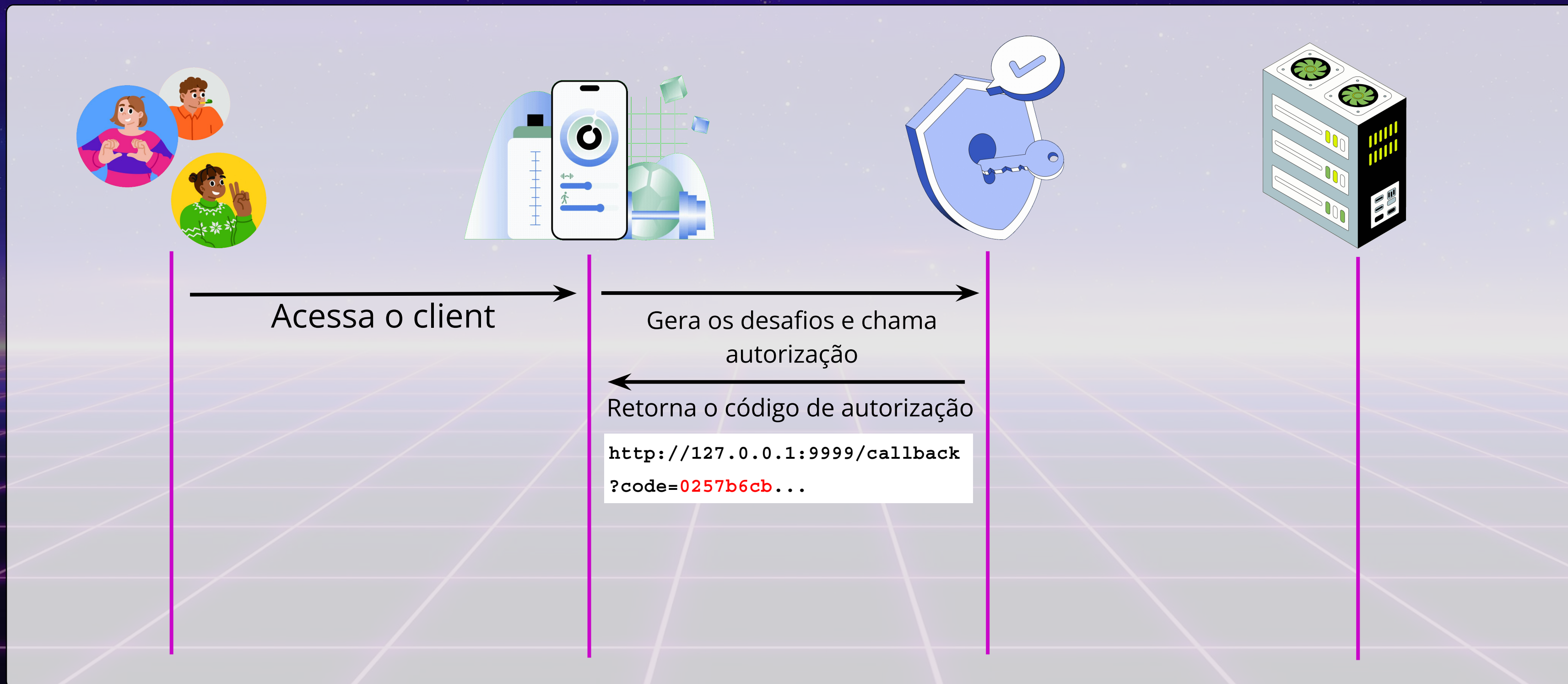
Code Challenge: String criptografada usando Code verifier como segredo



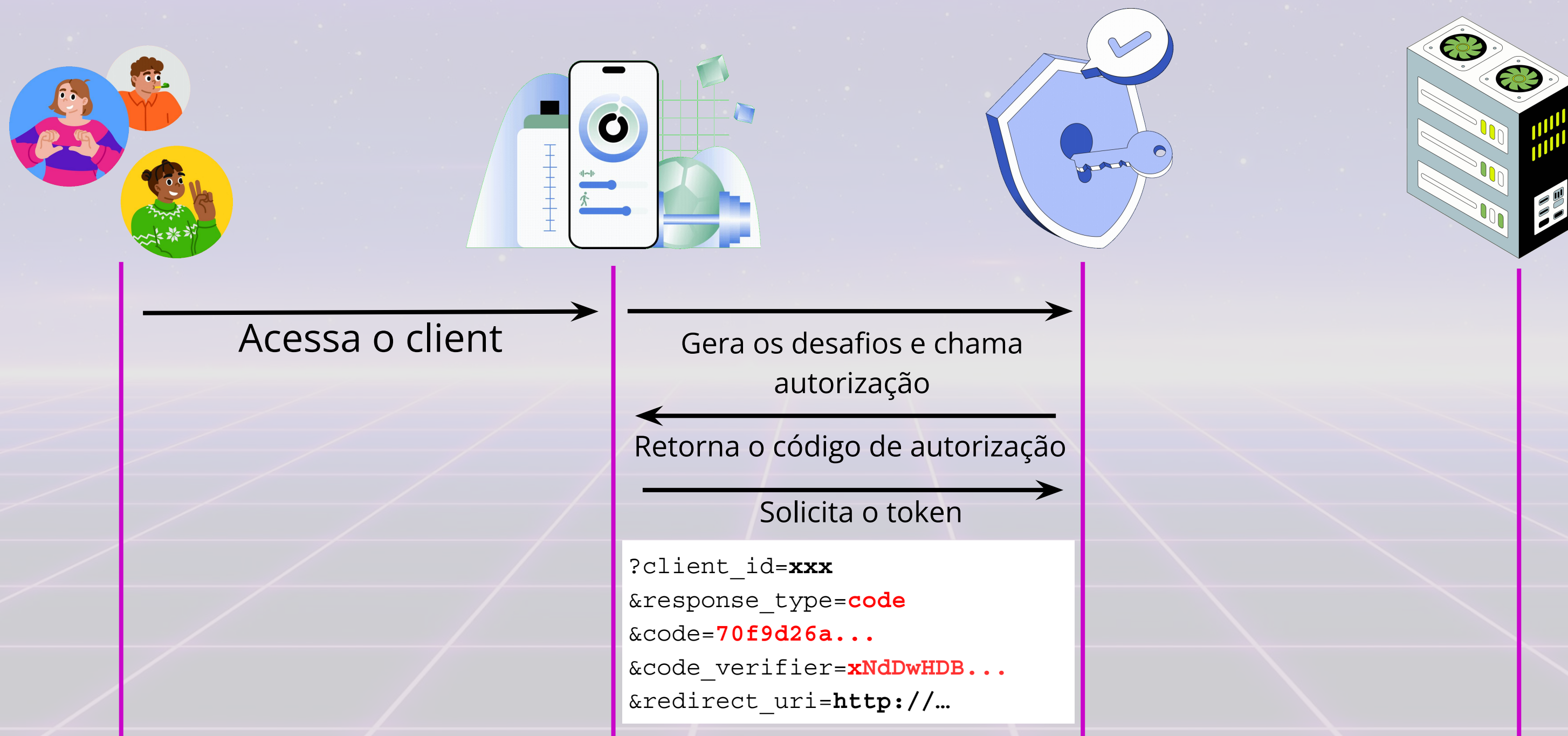
4. Authorization Code + PKCE



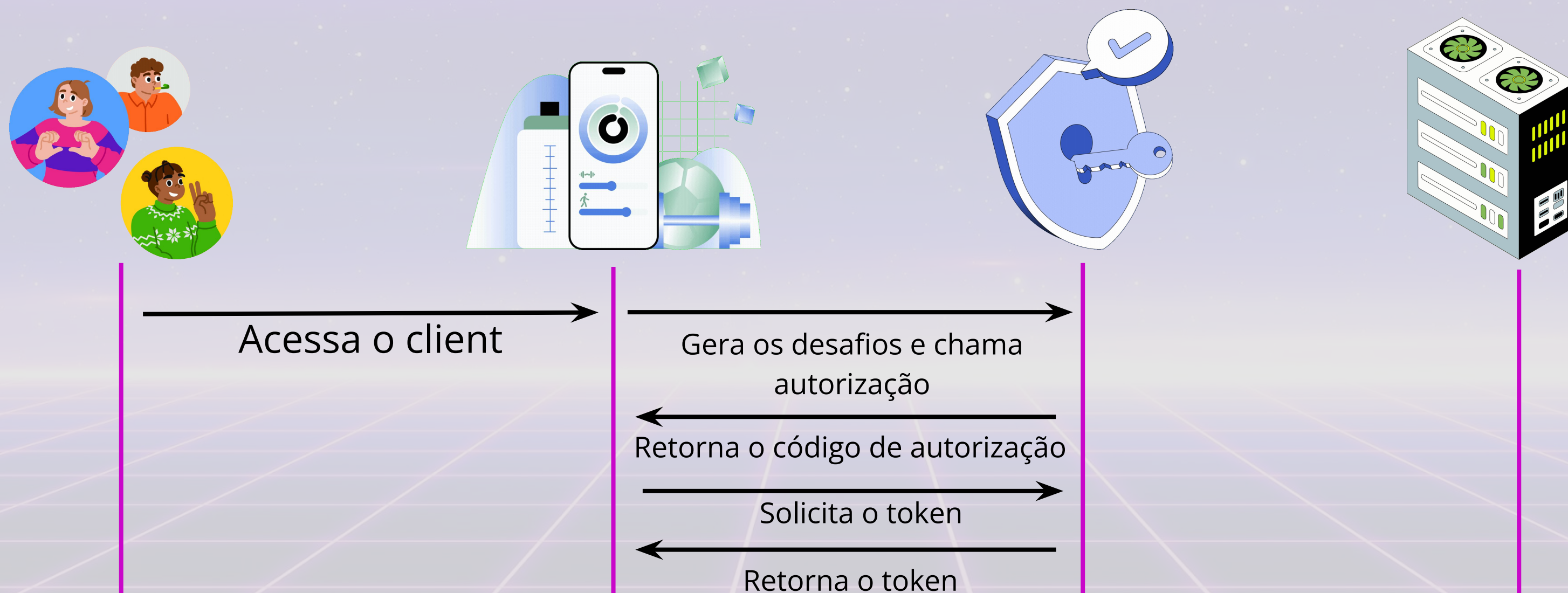
4. Authorization Code + PKCE



4. Authorization Code + PKCE



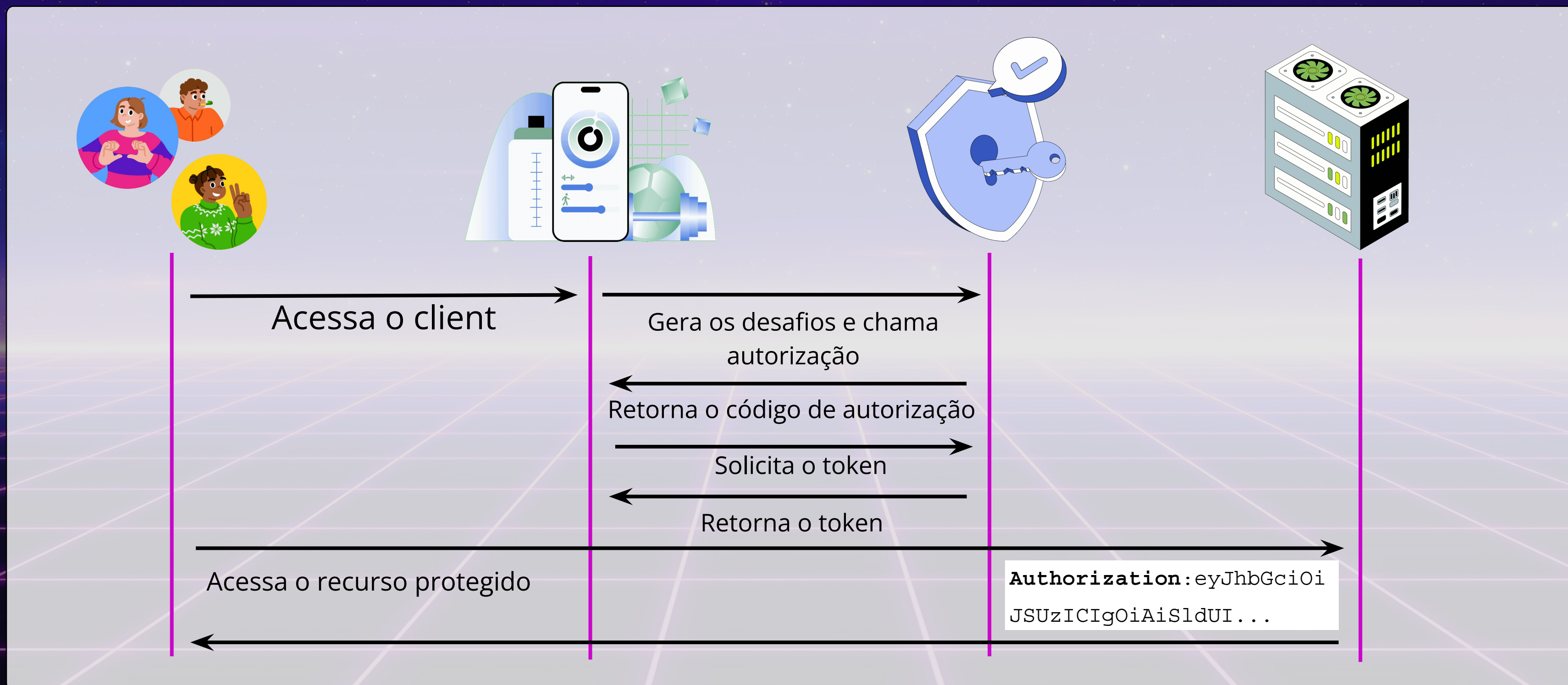
4. Authorization Code + PKCE



```
access_token:eyJhbGciOiJSUzI1NiIsInR5cCIgOiAiSldUIiwia2lk...  
refresh_token:eyJhbGciOiJIUzUxMiIsInR5cCIgOiAiSldUIiwia2lk...
```



4. Authorization Code + PKCE



E, claro, nada disso faz sentido se sua API não rodar em baixo de um HTTP Seguro



Avalie minha palestra lendo o QRCode pelo APP OFICIAL DO EVENTO



Permissões

Avalie minha palestra lendo o QrCode pelo APP OFICIAL DO EVENTO



Roles

Definem o que o usuário pode fazer dentro do sistema. As roles controlam acesso baseado em permissões do usuário.

```
"realm_access": {  
  "roles": [  
    "usuario.bi",  
    "supervisor"  
  ]  
},
```



Scopes

Autorização de acesso definida a nível de aplicação cliente, que limita quais ações ele pode solicitar à API, independente do Resource Owner autenticado

```
"scope": "email erp.read profile erp.write",
```



BORA PARA O CÓDIGO...

Aplicação	Fluxo OAuth	Scope(s)	Role(s)	Pode lançar?	Pode aprovar?
ERP Desktop	Authorization Code PKCE + Password flow	erp.write	supervisor	✓	✓
		erp.write		✓	✗
ERP - Backend	Client Credentials	erp.read		✗	✗
BI Mobile	Authorization Code PKCE + Password flow	bi.read	bi, supervisor	✗	✗

Avalie minha palestra lendo o QRCode pelo APP OFICIAL DO EVENTO



embarcadero®

EMBARCADERO CONFERENCE 2025

A JORNADA DO HERÓI | 30 ANOS DE INOVAÇÃO



Quer me ver na
#ECON26?
Acesse o QRCode e
avale minha palestra!



Gabriel Fabrega



@fabrega_dev



Gabriel Fabrega



gabriel.fabrega@outlook.com